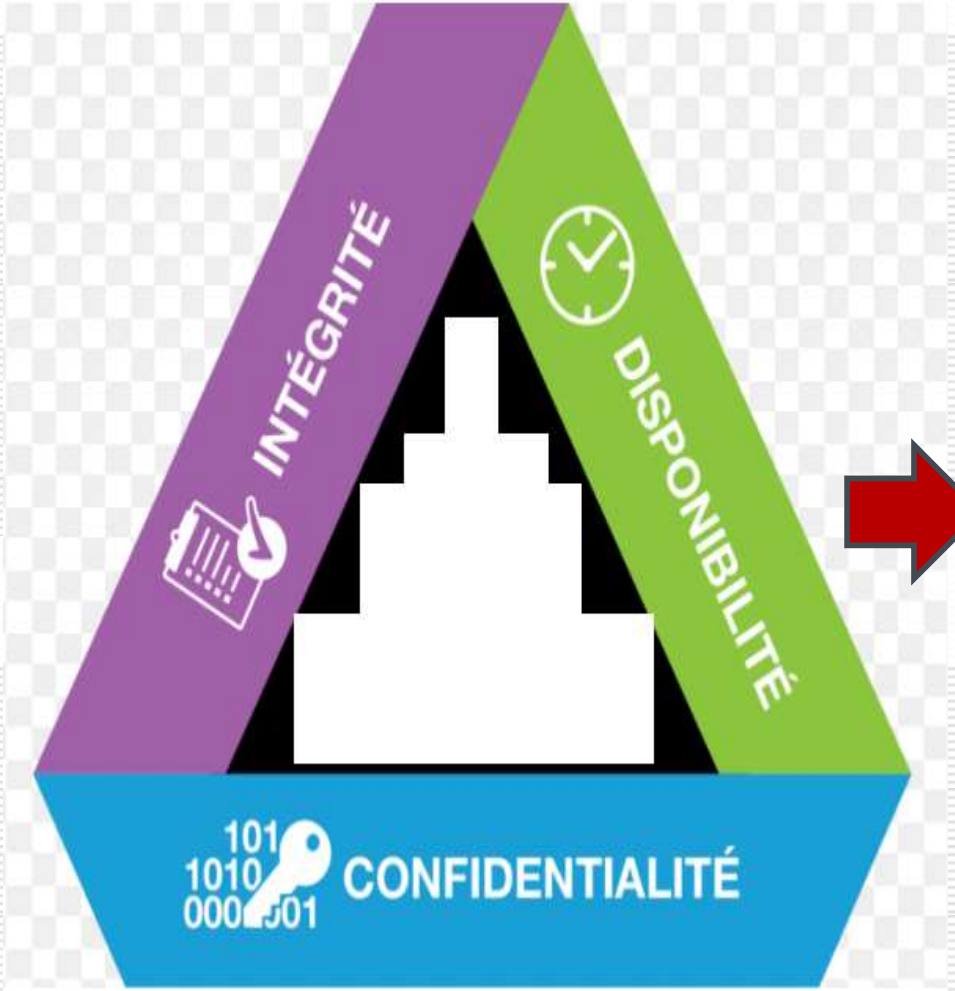
Chapitre 2

Les principales attaques sécuritaires

2026

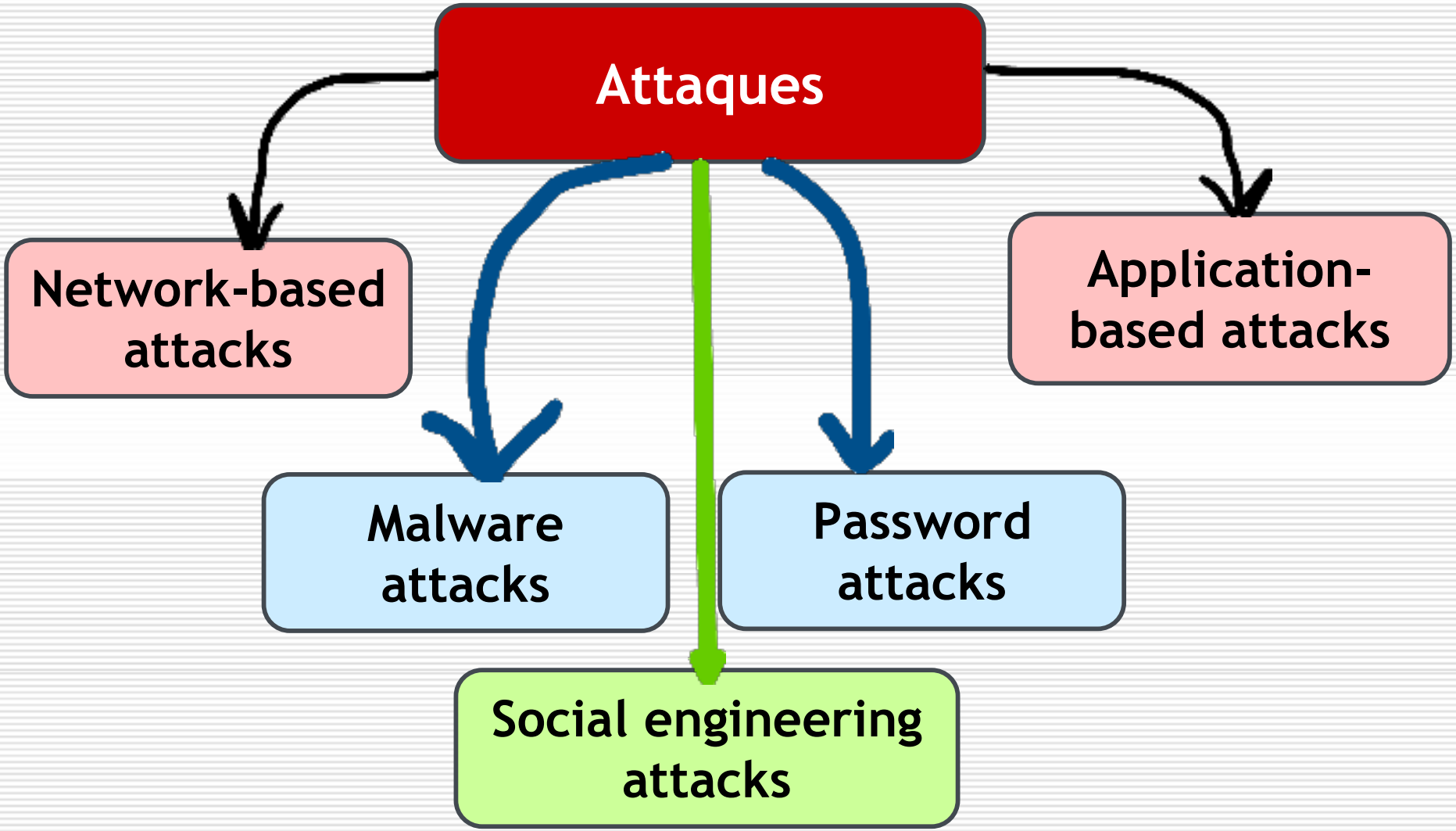


Rappel: Principes fondamentaux de la sécurité informatique



- Authentification
- Non-répudiation
- Autorisation / contrôle d'accès
- Traçabilité / audit

Attaques sécuritaires



Attaque par ingénierie sociale (1)



- Une **attaque par ingénierie sociale** (Social engineering) est une attaque qui vise avant tout l'être humain plutôt qu'une faille technique : l'attaquant manipule la victime afin qu'elle révèle une information sensible, donne un accès, télécharge un fichier malveillant ou effectue une action risquée. Le but peut être de voler un mot de passe, d'accéder à un réseau, de détourner de l'argent ou d'installer un logiciel malveillant

- Le **phishing** est une forme très fréquente d'ingénierie sociale : l'attaquant se présente comme une source digne de confiance pour pousser la victime à visiter un site frauduleux, communiquer ses identifiants ou installer un programme malveillant

Attaque par ingénierie sociale (2)

Principe de l'attaque

- L'attaquant exploite des mécanismes psychologiques courants :
- **L'urgence :** « Votre compte sera bloqué dans 30 minutes. »
- **L'autorité :** il se fait passer pour un responsable, un administrateur informatique, une banque ou une institution.
- **La confiance :** il imite une personne connue, un collègue ou un fournisseur.
- **La peur :** « Une activité suspecte a été détectée sur votre compte. »
- **La curiosité ou l'appât du gain :** « Voici votre prime », « Consultez cette photo », « Vous avez gagné un cadeau. »
- **L'entraide :** il prétend avoir besoin d'une aide rapide pour résoudre un problème.

⇨ L'objectif est de pousser la victime à agir sans vérifier : cliquer sur un lien, ouvrir une pièce jointe, donner un code MFA, communiquer un mot de passe ou autoriser une connexion distante.

Attaque par ingénierie sociale (3)

☐ Principales formes

Type d'attaque	Principe	Exemple
Phishing / hameçonnage	Faux courriel ou faux site web imitant une organisation de confiance	Un message prétend venir de Microsoft et demande de « réinitialiser » le mot de passe
Spear phishing	Phishing ciblé et personnalisé à partir d'informations sur la victime	Un étudiant reçoit un faux e-mail de son enseignant avec un « nouveau support de cours »
Vishing	Manipulation par appel téléphonique ou messagerie vocale	Un faux technicien appelle et demande un code de vérification
Smishing	Hameçonnage par SMS ou application de messagerie	« Votre colis est bloqué, payez 1,50 € ici »
Pretexting	Création d'un scénario crédible pour obtenir une information	Une personne se présente comme employée de la banque et demande de confirmer l'identité
Baiting	Utilisation d'un appât physique ou numérique	Une clé USB « Résultats examens » est laissée dans un lieu fréquenté
Quid pro quo	Promesse d'un service ou d'un avantage contre une information/action	Un faux support informatique propose une aide en échange des identifiants
Usurpation d'identité	L'attaquant se fait passer pour un collègue, un responsable ou un prestataire	Un e-mail du « directeur » demande un virement urgent
Tailgating	Accès physique obtenu en suivant une personne autorisée	L'attaquant entre dans un bâtiment sécurisé lorsqu'un employé lui tient la porte

Attaque par malware (1)

- Un **malware** (*malicious software*) est un programme ou un code introduit, souvent discrètement, dans un ordinateur, un téléphone, un serveur ou un réseau afin de compromettre :
  - la **confidentialité** : vol de mots de passe, données personnelles, documents ou informations bancaires
  - l'**intégrité** : modification, destruction ou chiffrement de fichiers
  - la **disponibilité** : blocage d'un ordinateur, arrêt d'un service ou saturation d'un réseau



Attaque par malware (2)

Type	Fonction principale	Exemple de conséquence
Virus	S'attache à un fichier ou programme et se propage lorsque celui-ci est exécuté	Contamination de plusieurs fichiers sur un poste
Ver informatique	Se propage automatiquement, souvent via un réseau, sans nécessiter de fichier hôte	Infection rapide de nombreux ordinateurs
Cheval de Troie	Se fait passer pour un programme légitime alors qu'il cache une fonction malveillante	Faux logiciel ou faux document qui ouvre un accès à l'attaquant
Rançongiciel / ransomware	Chiffre les données ou bloque l'accès, puis réclame une rançon	Serveur de fichiers inaccessible et demande de paiement
Logiciel espion / spyware	Collecte discrètement les informations de l'utilisateur	Vol de frappes clavier, mots de passe ou habitudes de navigation
Rootkit	Cache la présence d'un attaquant ou d'autres programmes malveillants	Persistance discrète avec privilèges élevés
Bot / botnet	Transforme l'appareil infecté en machine contrôlée à distance	Participation à une attaque DDoS ou envoi massif de spam
Keylogger	Enregistre les frappes au clavier	Récupération d'identifiants et de mots de passe

Attaque par malware (3)

- **Exemple d'attaque par Malware**
  - Un user reçoit un e-mail qui semble venir de son établissement :

```
Objet : Nouveau planning des examens
Bonjour,
Veuillez télécharger le fichier joint afin de consulter la mise à
jour urgente du planning.
```

  - La pièce jointe contient un fichier tel que **Planning_examens.exe** ou un document Office avec une macro
  - Une fois ouvert, le programme installe un cheval de Troie.
  - Celui-ci peut ensuite :Créer un accès distant pour l'attaquant.
  - Voler les mots de passe enregistrés dans le navigateur.
  - Télécharger d'autres malwares.
  - Chiffrer les fichiers et déclencher un ransomware.
  - Se propager vers les partages réseau de l'organisation

Attaque par malware (4)

- **Signes possibles d'infection par malware**
  - Certains comportements peuvent indiquer une infection, sans être une preuve à eux seuls :
    - Ordinateur anormalement lent ou instable.
    - Fenêtres publicitaires inhabituelles ou redirections dans le navigateur.
    - Antivirus désactivé sans action de l'utilisateur.
    - Programmes inconnus qui démarrent automatiquement.
    - Fichiers renommés, chiffrés ou devenus inaccessibles.
    - Activité réseau inhabituelle.
    - Alertes de sécurité ou demande de rançon.
    - Connexions suspectes depuis un compte utilisateur.

Attaque par mot de passe (1)

- Une **attaque par mot de passe** elle vise à deviner, voler, réutiliser ou contourner les identifiants d'un utilisateur afin d'accéder à un compte, un ordinateur, une application, un serveur, un réseau... Elle peut compromettre la confidentialité, permettre une élévation de privilèges ou servir de point d'entrée à une attaque plus grave, comme un ransomware

Combien de temps faut-il à un pirate pour trouver votre mot de passe 2025

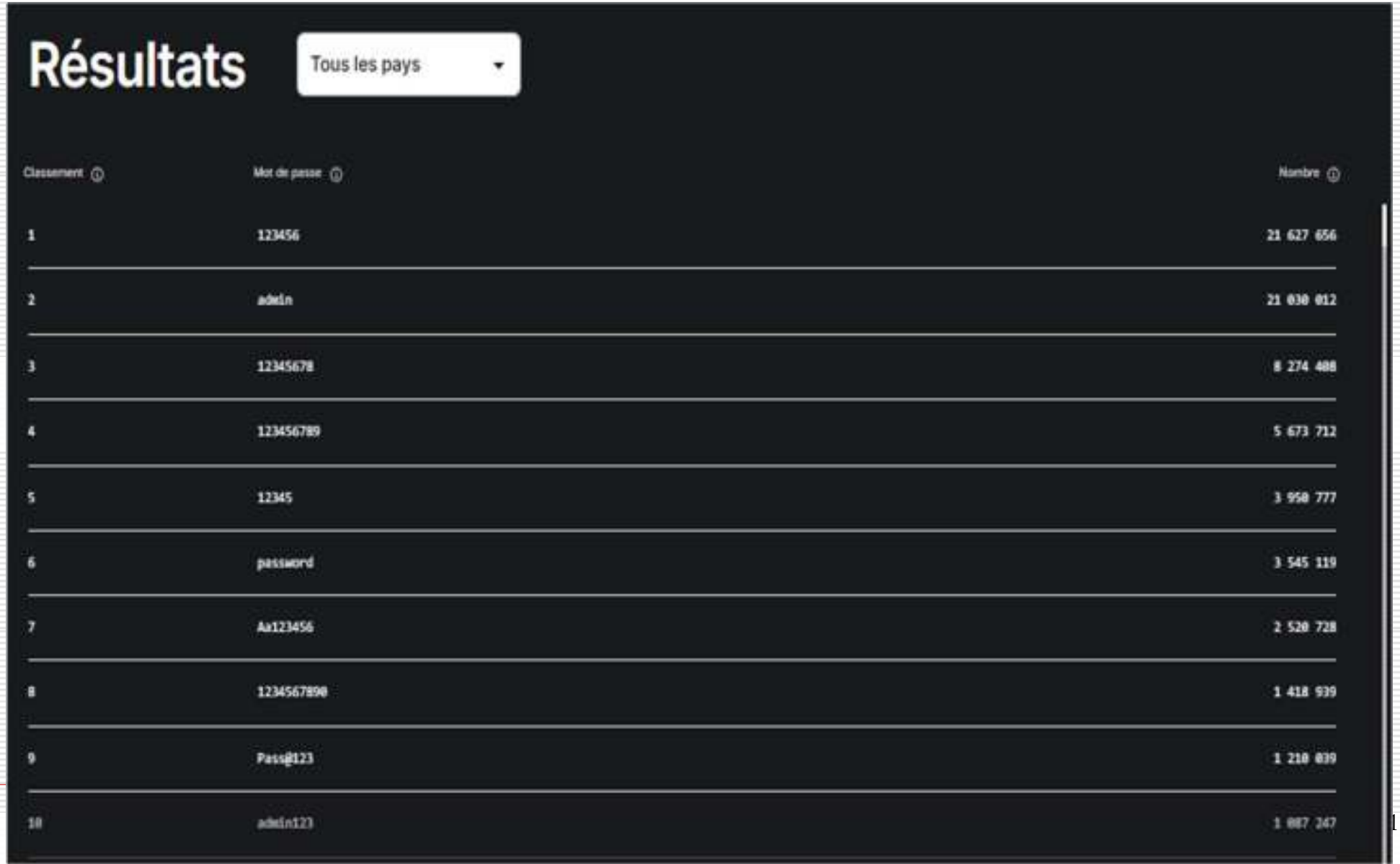
Nombre de caractères	Nombres seulement	Lettres minuscules	Lettres majuscules et minescules	Nombres, lettres majuscules et minuscules	Nombres, lettres majuscules et minuscules, symboles
4	Instantané	Instantané	Instantané	Instantané	Instantané
5	Instantané	Instantané	57 minutes	2 heures	4 heures
6	Instantané	46 minutes	2 jours	6 jours	2 semaines
7	Instantané	20 heures	4 mois	1 an	2 ans
8	Instantané	3 semaines	15 ans	62 ans	164 ans
9	2 heures	2 ans	791 ans	3k ans	11k ans
10	1 jour	40 ans	41k ans	238k ans	803k ans
11	1 semaine	1k ans	2M ans	14M ans	56M ans
12	3 mois	27k ans	111M ans	917M ans	3Md ans
13	3 ans	705k ans	5Md ans	56Md ans	275Md ans
14	28 ans	18M ans	300Md ans	3Bn ans	19Bn ans
15	284 ans	477M ans	15Bn ans	218Bn ans	1Bd ans
16	2k ans	12Md ans	812Bn ans	13Bd ans	94Bd ans
17	28k ans	322Md ans	42Bd ans	840Bd ans	6Tn ans
18	284k ans	8Bn ans	2Tn ans	52Tn ans	463Tn ans

Attaque par mot de passe (2)

Type d'attaque	Principe	Exemple
Force brute	L'attaquant teste un très grand nombre de combinaisons de mots de passe sur un compte	Essais automatisés de milliers de mots de passe sur `admin`
Attaque par dictionnaire	L'attaquant essaie une liste de mots de passe fréquents, mots du dictionnaire, noms, dates ou combinaisons connues	`azerty`, `password`, `123456`, `Tunisie2026`
Password spraying	Un ou quelques mots de passe fréquents sont essayés sur un grand nombre de comptes	Essayer `Password123!` sur les comptes d'une entreprise
Credential stuffing	Réutilisation automatique de couples identifiant/mot de passe obtenus lors d'une fuite de données	Utiliser les identifiants volés d'un ancien site sur Gmail, Facebook ou un VPN
Phishing	Vol du mot de passe au moyen d'un faux e-mail ou d'un faux site de connexion	Fausse page Microsoft 365 demandant l'identifiant et le mot de passe
Keylogging	Enregistrement des frappes clavier par un logiciel malveillant	Le malware capture le mot de passe saisi dans un navigateur
Interception réseau	Récupération de mots de passe transmis de manière non protégée	Connexion à un site HTTP ou à un service ancien non chiffré
Vol physique ou observation	Récupération par observation, papier laissé visible ou accès à un appareil déverrouillé	Un mot de passe écrit sur un post-it près de l'écran

Attaque par mot de passe (3)

- Dictionnaire de mots de passe



Résultats

Tous les pays

Classement	Mot de passe	Nombre
1	123456	21 627 656
2	admin	21 030 012
3	12345678	8 274 408
4	123456789	5 673 712
5	12345	3 950 777
6	password	3 545 119
7	Aa123456	2 520 728
8	1234567890	1 418 939
9	Pass@123	1 210 039
10	admin123	1 087 247

Attaque par mot de passe (4)

- **Comment se protéger ?**
  - **Longueur et complexité :** Utilisez des phrases secrètes d'au moins 12 à 15 caractères mélangeant majuscules, minuscules, chiffres et caractères spéciaux.
  - **Gestionnaires de mots de passe** : Stockez vos identifiants dans un coffre-fort numérique sécurisé pour générer des codes uniques et aléatoires pour chaque site
  - **Authentification Multifacteur (MFA) :** Ajoutez une couche de sécurité supplémentaire (code par SMS, OTP, application d'authentification ou clé matérielle)

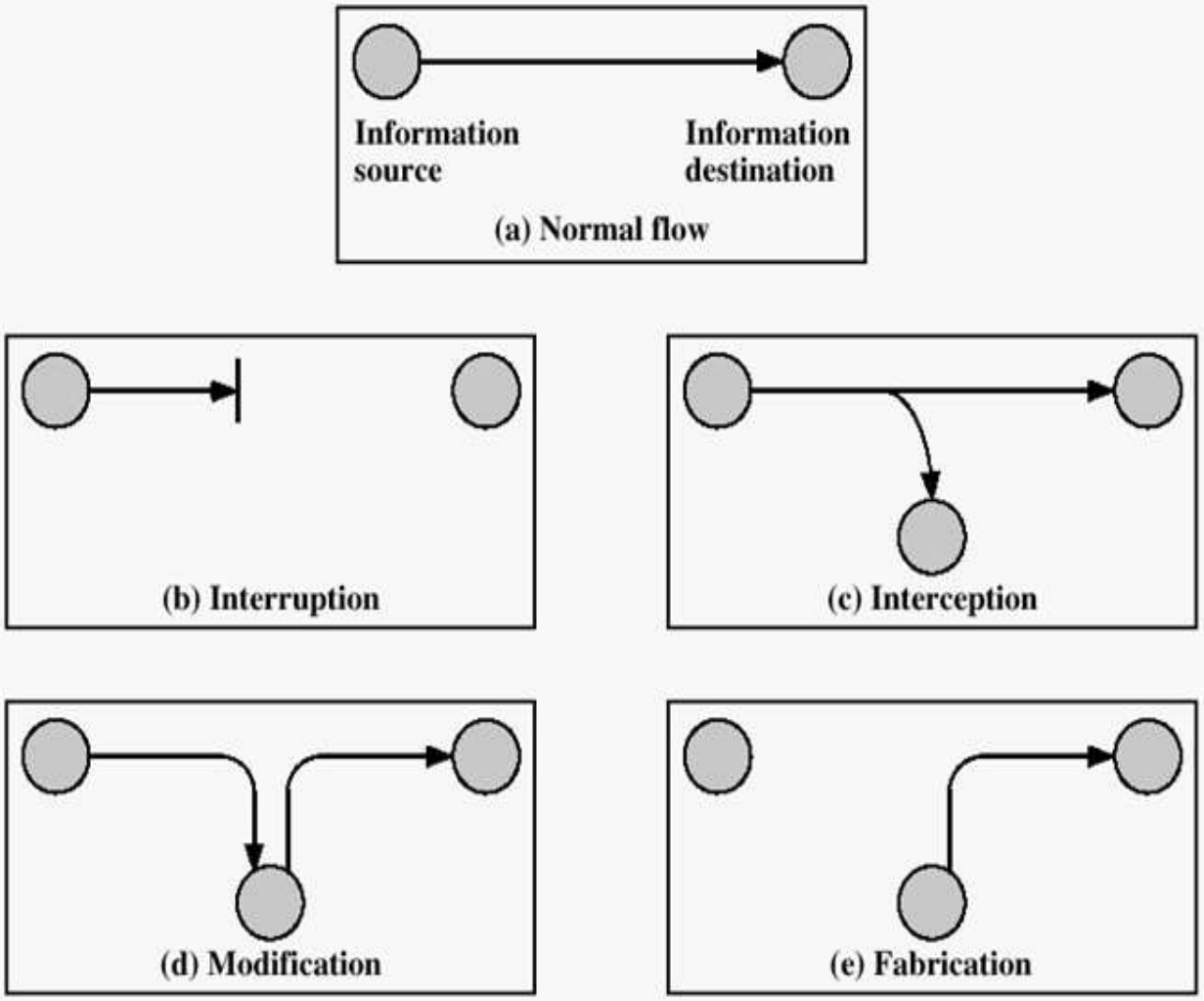
- **Note :**
  - Une étude Microsoft sur les comptes analysés rapporte que plus de 99,99% des comptes protégés par MFA sont restés sécurisés durant la période étudiée

Network-based attacks

Les attaques basées sur le réseau sont des attaques qui exploitent:

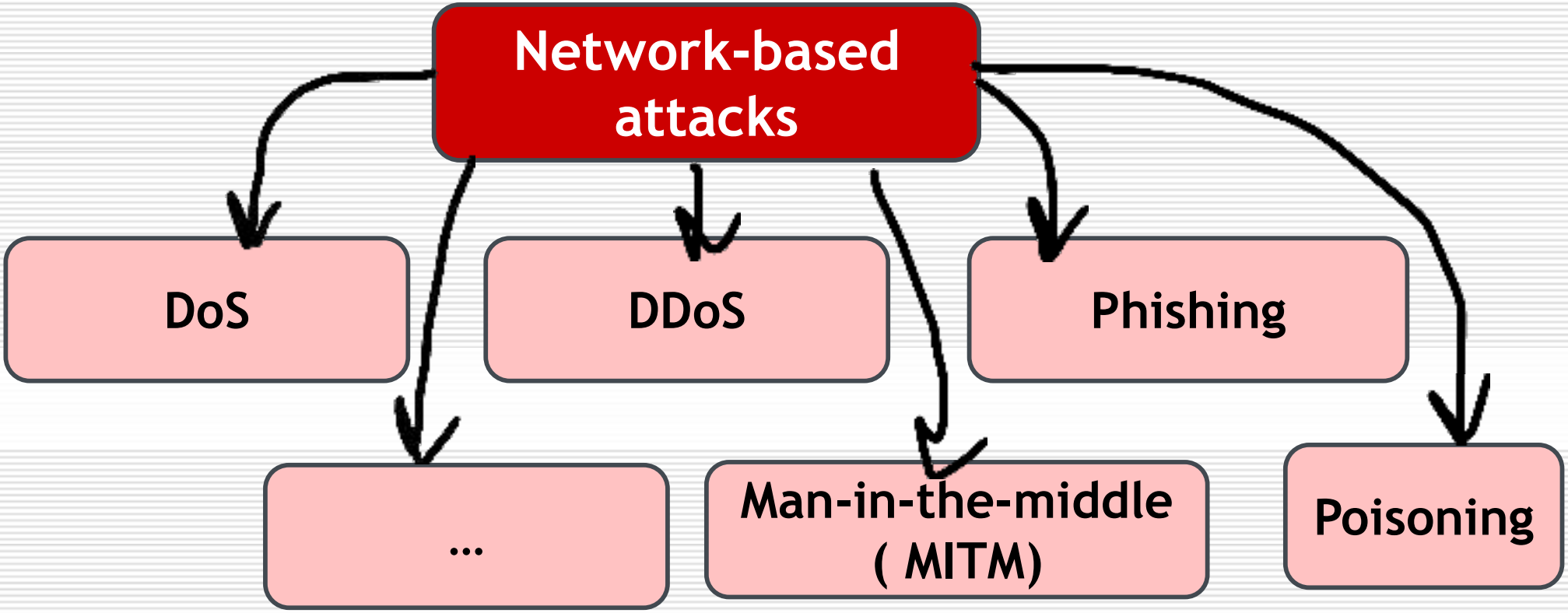
- les failles des infrastructures de communication
- des protocoles réseau pour perturber les services, intercepter des données ou manipuler les échanges entre systèmes

Network-based attacks & CIA principles



- **Interruption:** This is an attack on availability
- **Interception:** This is an attack on confidentiality
- **Modification:** This is an attack on integrity
- **Fabrication:** This is an a ttack on authenticity

Principales attaques réseaux



Phishing/Hameçonnage (1)

- Le phishing prend souvent la forme d'un e-mail ou d'un message qui semble provenir d'une source fiable (banque, administration, entreprise reconnue)
- L'objectif est de pousser la victime à cliquer sur un lien frauduleux, à ouvrir une pièce jointe malveillante, ou à fournir volontairement des informations personnelles (identifiants de connexion, mots de passe, coordonnées bancaires, ou autres données confidentielles,..) sur un faux site web qui imite un site légitime



Phishing/Hameçonnage (2)

Exemple d'attaque par phishing :

- Entre **2013 et 2015 Facebook (Meta) a été victime d'une fraude par phishing/BEC qui lui a coûté environ 98 millions de dollars**, dans une escroquerie qui a également touché Google pour environ 23 millions de dollars. Le montant total détourné dépassait donc 120 millions de dollars

- Un fraudeur lituanien nommé Evaldas Rimasauskas a mis en place une forme sophistiquée de phishing appelée **Business Email Compromise** (BEC)/ *fraude aux faux fournisseurs*

- Il n'a pas piraté directement les serveurs de Facebook et Google. Il a plutôt trompé leurs employés chargés de valider des paiements afin qu'ils virent de l'argent vers les comptes bancaires contrôlés par les fraudeurs

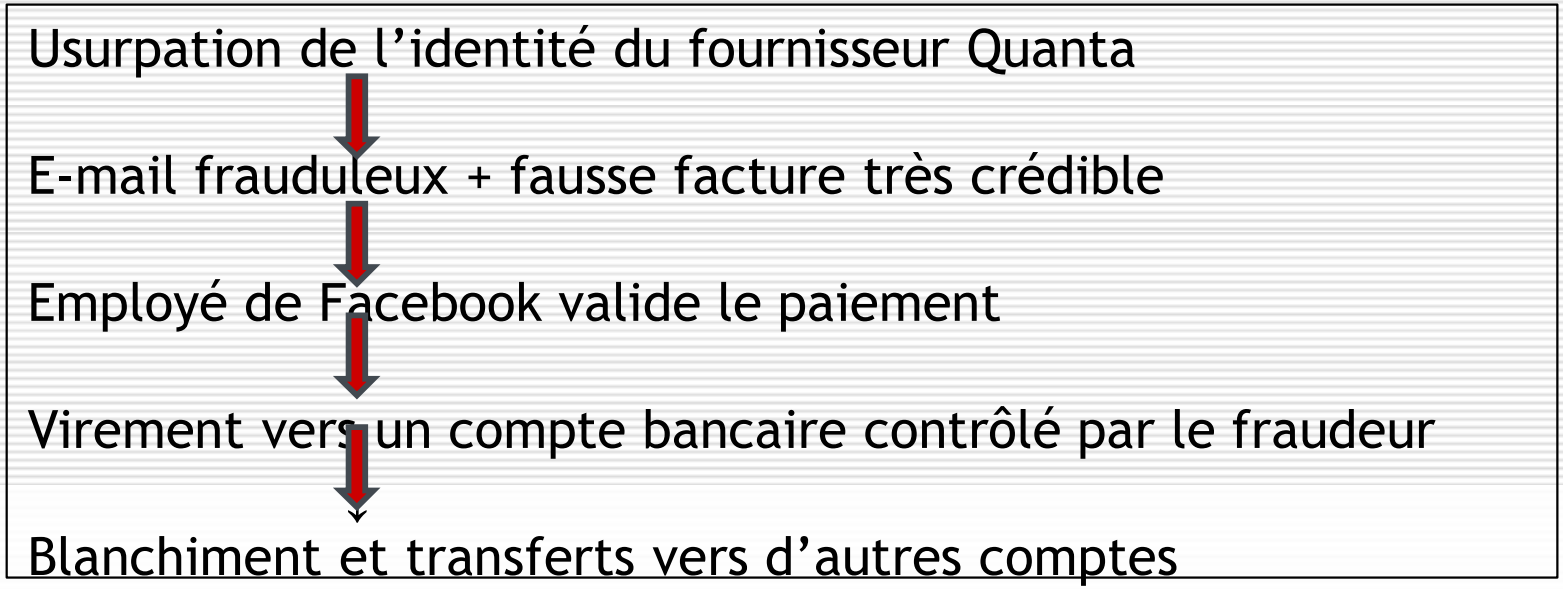
Phishing/Hameçonnage (3)

Comment la fraude a fonctionné?

- Rimasauskas a imité Quanta Computer, une entreprise taïwanaise de matériel informatique avec laquelle Facebook et Google travaillaient réellement
- Les fraudeurs ont notamment :
  - Créé une entreprise et des comptes bancaires donnant l'apparence d'être liés au véritable fournisseur.
  - Utilisé des adresses e-mail proches ou usurpant l'identité de Quanta.
  - Envoyé des e-mails de phishing aux employés concernés.
  - Produit de fausses factures pour des livraisons ou prestations informatiques fictives.
  - Fabriqué de faux contrats, lettres, signatures et tampons d'entreprise.
  - Demandé que les paiements soient réalisés par virement bancaire vers des comptes contrôlés par eux

Phishing/Hameçonnage (4)

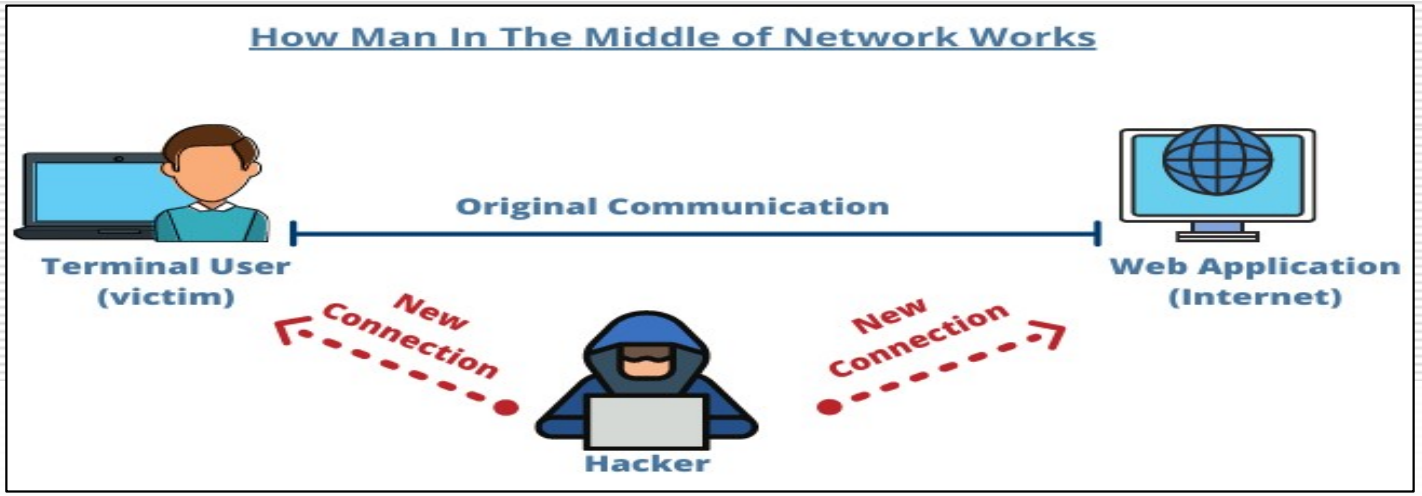
- **Schéma de l'attaque**



- Les attaques auxquelles la société Meta a subi :
  - **Spear phishing :** e-mails très ciblés et adaptés à la victime
  - **Usurpation d'identité de fournisseur :** imitation d'un partenaire réel
  - **BEC :** fraude qui vise les équipes finance, achats, direction ou comptabilité
  - **Ingénierie sociale :** manipulation d'une personne plutôt qu'exploitation d'une faille technique.

Man-in-the-middle attack (MITM) (1)

- Une attaque MITM est une cyberattaque au cours de laquelle un pirate informatique vole des informations sensibles en écoutant les communications entre deux cibles **en ligne**

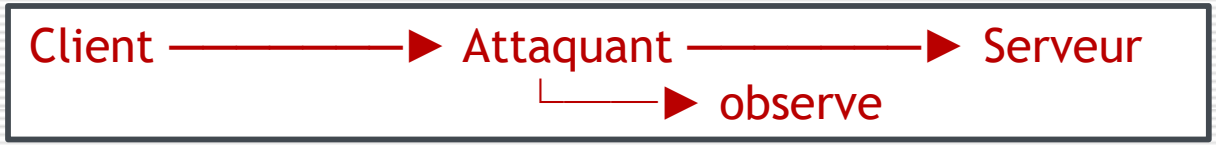


- Comment fonctionne une attaque de type MITM?
  - Les vulnérabilités des réseaux, des navigateurs web, des comptes de messagerie, du comportement des utilisateurs et des protocoles de sécurité sont le point de départ des attaques de type MITM
  - Le **phishing** est une voie d'entrée courante pour les attaquants MITM

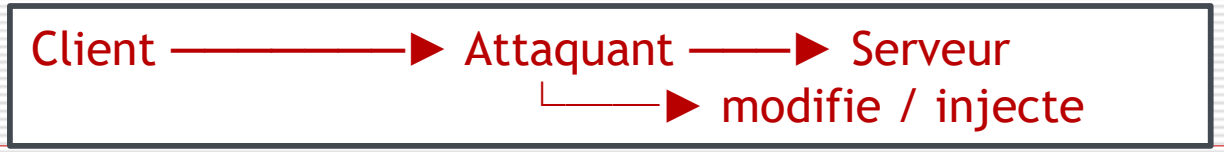
Man-in-the-middle attack (MITM) (2)

Que peut faire l'attaquant ?

- Selon le type de MITM, l'attaquant peut :
  - **écouter** les communications ;
  - **intercepter** des données ;
  - **modifier** les messages ;
  - **voler des informations d'authentification** ;
  - récupérer des cookies de session dans certaines situations ;
  - rediriger l'utilisateur vers un autre site ;
  - récupérer des informations sensibles ;
  - injecter de fausses informations dans la communication
- On distingue donc notamment :
  - **MITM passif**

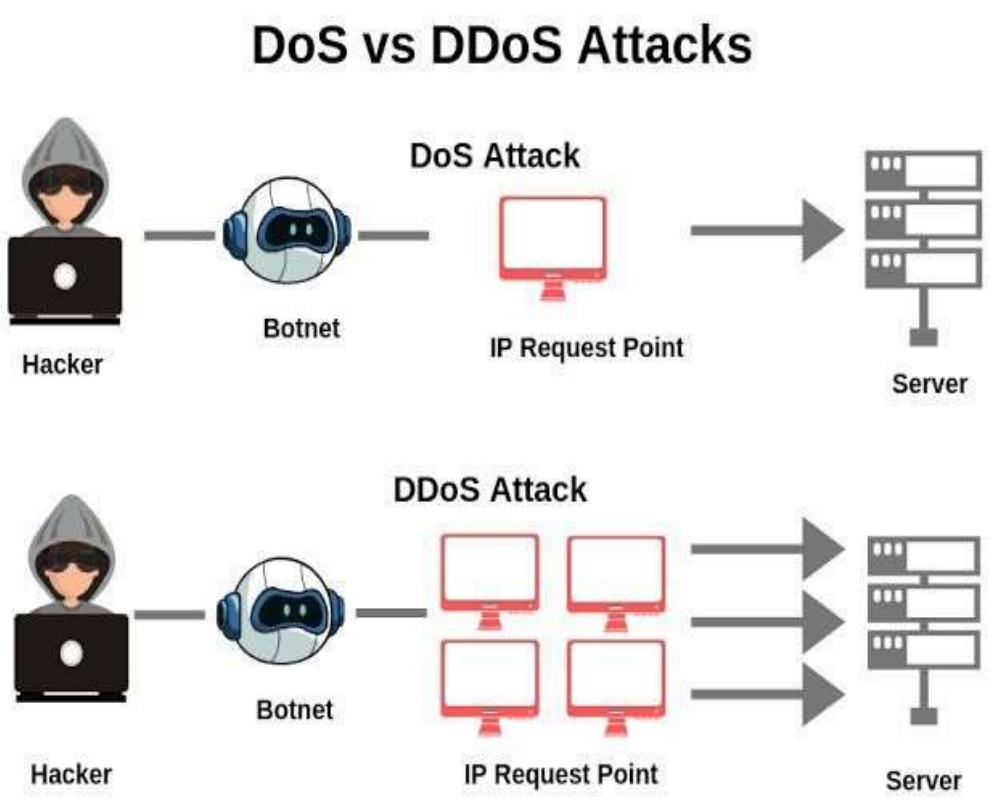


  - **MITM actif**



Denial-of-Service (DoS) & DDoS attacks (1)

- Les attaques par déni de service (DoS) ou déni de service distribué (DDoS) consistent à **inonder** une ressource en ligne (un site Web, un service cloud …) de demandes de connexion frauduleuses ou d'autres types de trafic malveillant
- Incapable de gérer ce trafic, la cible **ralentit** ou **tombe en panne**, ce qui la rend inaccessible pour les utilisateurs légitimes
- **Différence entre attaques DoS & DDoS**
  - La principale différence est que pour le premier l'attaque vient d'un **seul** système, tandis que pour le second implique **plusieurs** systèmes simultanément



Denial-of-Service (DoS) & DDoS attacks (2)

- **Types d'attaques DoS et DDoS**
  - **Attaque Teardrop:** Une attaque Teardrop est une attaque DoS qui envoie d'innombrables fragments de données de protocole Internet (Internet Protocol, IP) à un réseau. Lorsque le réseau tente de recompiler les fragments dans leurs paquets d'origine, il n'y parvient pas
  - **Attaque par saturation:** elle consiste à envoyer plusieurs demandes de connexion à un serveur, mais ensuite ne répond pas pour établir la liaison
  - **Attaque volumétrique:** elle consiste à consommer la bande passante en vain. Par exemple, l'attaquant utilise un réseau zombie pour envoyer un volume élevé de paquets de requêtes à un réseau, submergeant sa largeur de bande de requêtes d'écho d'Internet Control Message Protocol (ICMP). Cela entraîne un ralentissement ou même l'arrêt total des services.

Denial-of-Service (DoS) & DDoS attacks (3)

- **Comment améliorer la protection contre les attaques DDoS & DoS**
  - Surveiller le réseau en permanence pour identifier les modèles de trafic normaux et anormaux
  - Effectuer des tests pour simuler des attaques DoS : cela permettra d'évaluer les risques, d'exposer les vulnérabilités et de former les employés à la cybersécurité.
  - Créer un plan de protection
  - Identifier les systèmes critiques et les modèles de trafic normaux: les premiers permettent de planifier la protection et les seconds permettent la détection précoce des menaces.
  - Prévoir une largeur de bande supplémentaire : elle n'arrêtera peut-être pas l'attaque, mais elle aidera le réseau à faire face aux pics de trafic et à réduire l'impact de toute attaque.

Denial-of-Service (DoS) & DDoS attacks (4)

- **Exemple d'attaque par DDoS:**
  - Le 21 octobre 2016, Dyn, un fournisseur de DNS américain, a subi une attaque DDoS majeure
  - L'attaque a utilisé le botnet **Mirai**. Ce malware a compromis un grand nombre d'objets connectés mal sécurisés, notamment des caméras IP, DVR et autres appareils IoT. Ces appareils ont ensuite envoyé massivement du trafic vers Dyn

  - **Conséquences :**
    - L'accès à de grands services comme Twitter/X, Netflix, PayPal, Spotify, Reddit, Airbnb et GitHub a été perturbé pour de nombreux utilisateurs
    - La cible directe était Dyn, mais l'impact s'est propagé à ses clients
    - L'affaire a montré qu'un appareil IoT avec un mot de passe par défaut ou faible peut devenir une arme dans une attaque globale

Attaque par empoisonnement ARP (1)

- Une attaque de "poisoning" désigne diverses actions malveillantes qui visent à corrompre ou à manipuler des données ou des systèmes

- **Objectif**
  - Perturber les systèmes, détourner le trafic réseau, voler des informations ou de rediriger des utilisateurs vers des sites frauduleux, …

- **Types d'attaques par empoisonnement**
  - **empoisonnement de données :** introduisant des informations fausses et nuisibles
  - **Empoisonnement ARP** : exploitant des faiblesses dans des protocoles de communication
  - **Empoisonnement de cache :** injectant des contenus malveillants dans des caches

Attaque par empoisonnement ARP (2)

- **Empoisonnement ARP (ARP Poisoning) :** c'est une attaque qui exploite les faiblesses du protocole ARP
  - **Objectif :** Modifier le tableau des correspondances d'adresses IP et MAC d'un réseau local (LAN)
  - **Exemple :** L'attaquant envoie de faux messages ARP à la passerelle réseau, ce qui lui permet **d'intercepter** et **de modifier** tout le trafic réseau passant par lui pour un utilisateur ciblé.

Attaque par empoisonnement ARP (3)

- Fonctionnement normal de ARP



IPv4	MAC
192.168.1.254	00:00:00:00:00:02
192.168.1.150	00:00:00:00:00:03

IPv4	MAC
192.168.1.100	00:00:00:00:00:01
192.168.1.150	00:00:00:00:00:03

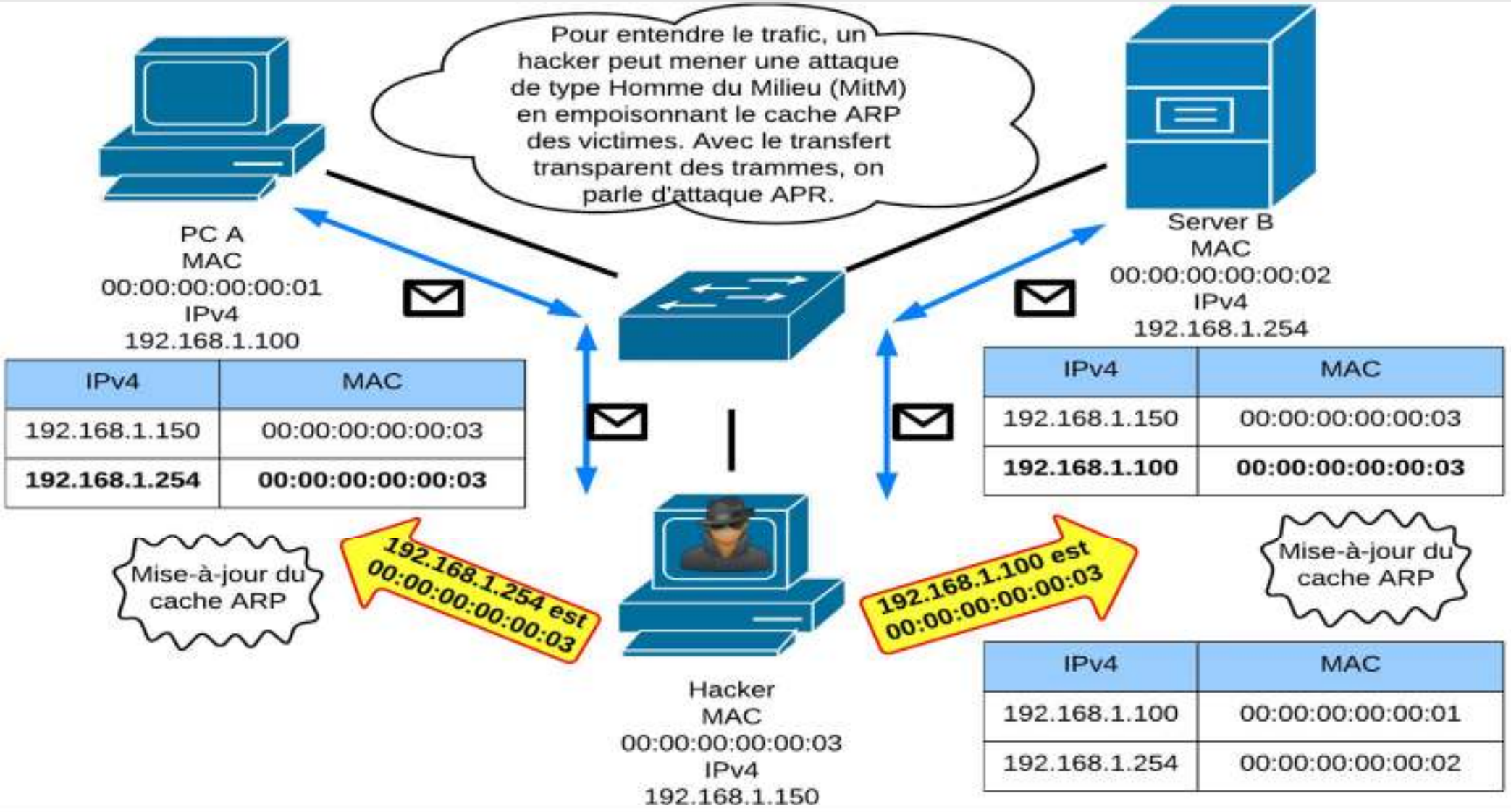


Hacker
MAC
00:00:00:00:00:03
IPv4
192.168.1.150

IPv4	MAC
192.168.1.100	00:00:00:00:00:01
192.168.1.254	00:00:00:00:00:02

Attaque par empoisonnement ARP (4)

Attaque par empoisonnement ARP



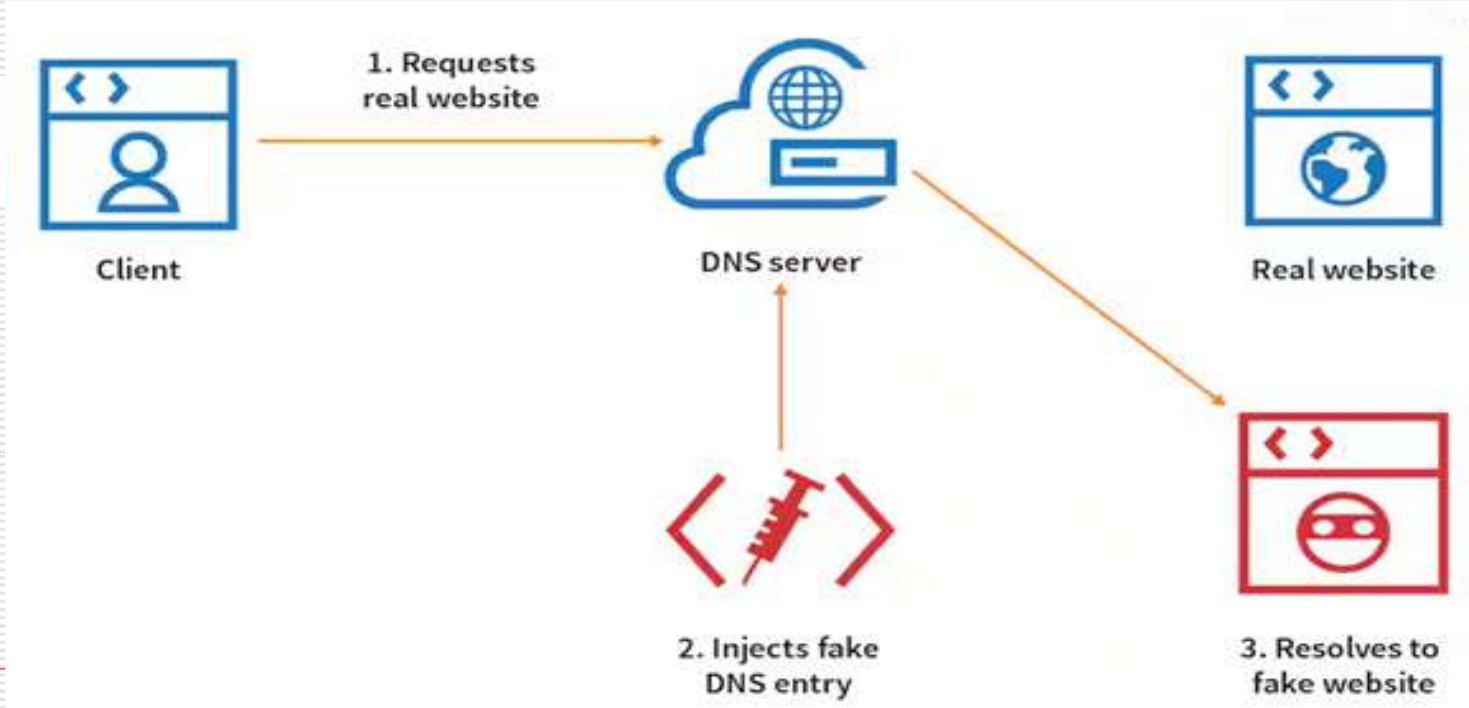
IPv4	MAC
192.168.1.150	00:00:00:00:00:03
192.168.1.254	**00:00:00:00:00:03**

IPv4	MAC
192.168.1.150	00:00:00:00:00:03
192.168.1.100	**00:00:00:00:00:03**

IPv4	MAC
192.168.1.100	00:00:00:00:00:01
192.168.1.254	00:00:00:00:00:02

Attaque par empoisonnement du cache DNS (DNS Cache Poisoning)

- Dans une attaque par empoisonnement du cache DNS, les auteurs de la menace utilisent différentes techniques pour remplacer les adresses légitimes dans un cache DNS par de fausses adresses DNS.
- Lorsque les utilisateurs tentent de consulter un site légitime, le résolveur DNS renvoie **la fausse adresse** dans son cache, détournant la session du navigateur et envoyant l'utilisateur vers un **faux site Web** ou un **site Web malveillant**.



Application-based attacks

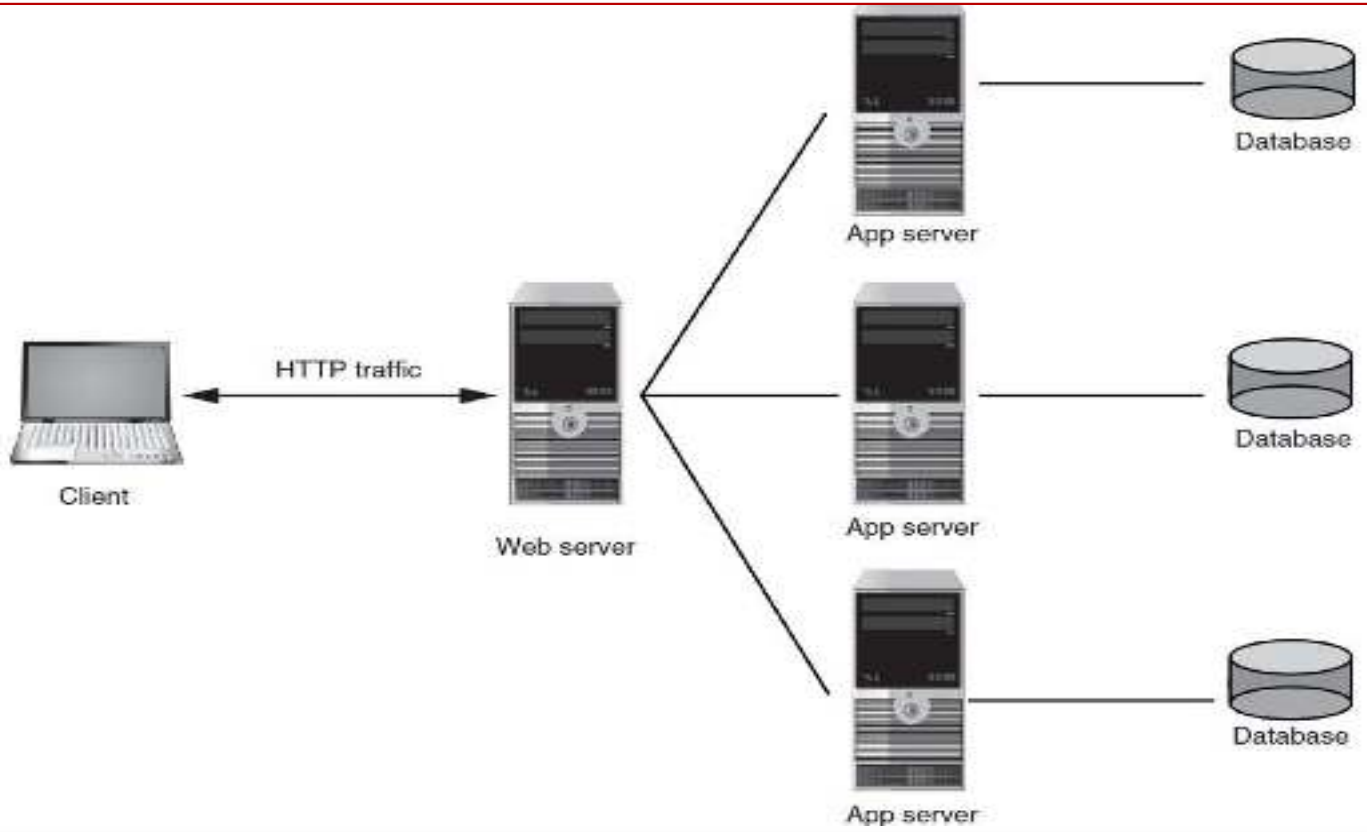
A typical Server-side Web application infrastructure

An important characteristic of server-side web applications is that they create dynamic content based on inputs from the user. For example, a webpage might ask a user to enter her zip code in order to receive the latest weather forecast for that area. Thus the dynamic operations of a web application depend heavily upon inputs provided by users.

Securing server-side web applications is often considered more difficult than protecting other systems. First, although traditional network security devices can block traditional network attacks, they cannot always block web application attacks. This is because many traditional network security devices ignore the *content* of HTTP traffic, which is the vehicle of web application attacks. Second, many web application attacks (as well as other application attacks) exploit previously unknown vulnerabilities. Known as **zero-day attacks**, these attacks give victims no time—zero days—to defend against the attacks. Finally, by design the dynamic server-side web applications accept user input, such as the zip code of the region for which a weather forecast is needed. Most other systems would categorically reject any user input as potentially dangerous, not knowing if the user is a friend or foe.

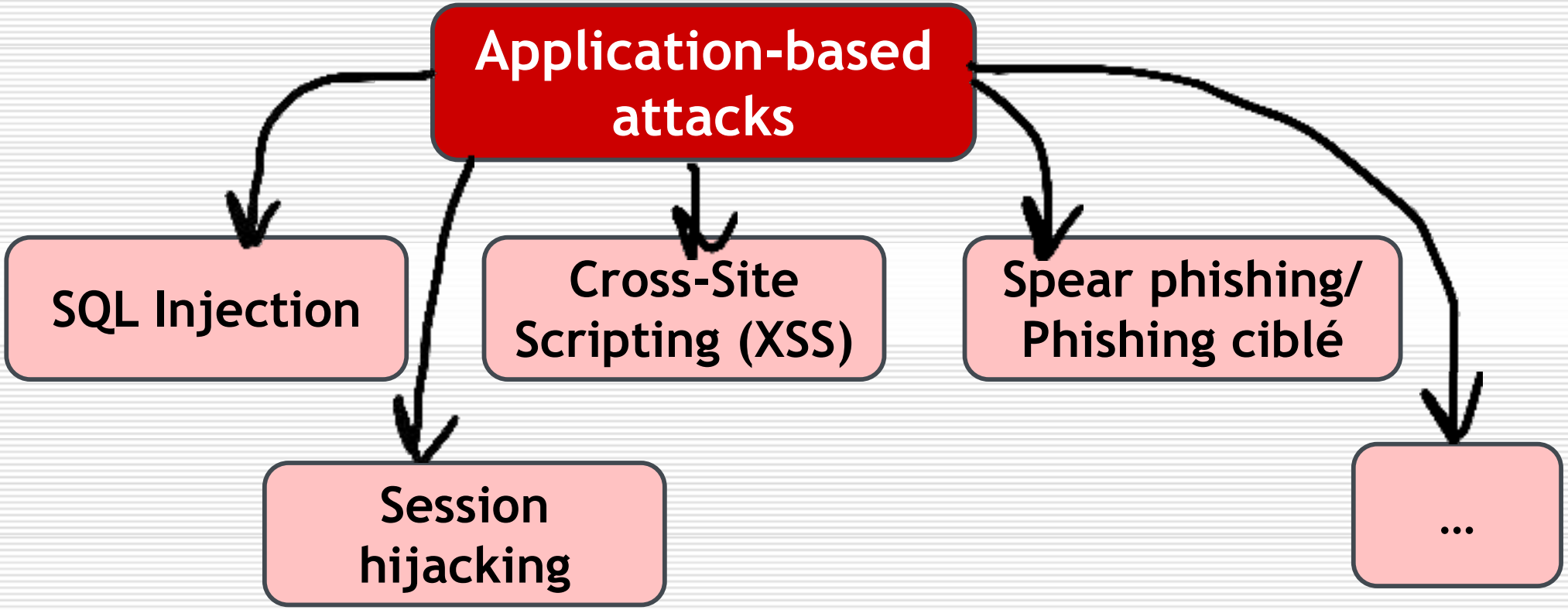
A typical Server-side Web application infrastructure

A typical dynamic web application infrastructure is shown in Figure 2. The client's web browser makes a request using the Hypertext Transport Protocol (HTTP) to a web server, which may be connected to one or more web application servers. These application servers run the specific "web apps," which in turn are directly connected to databases on the internal network. Information from these databases is retrieved and returned to the web server so that the dynamic information can be sent back to the user's web browser.



Attaques sécuritaires

Many server-side web application attacks target the input that the applications accept from users. Such common web application attacks are cross-site scripting, SQL injection, XML injection, and command injection/directory traversal.

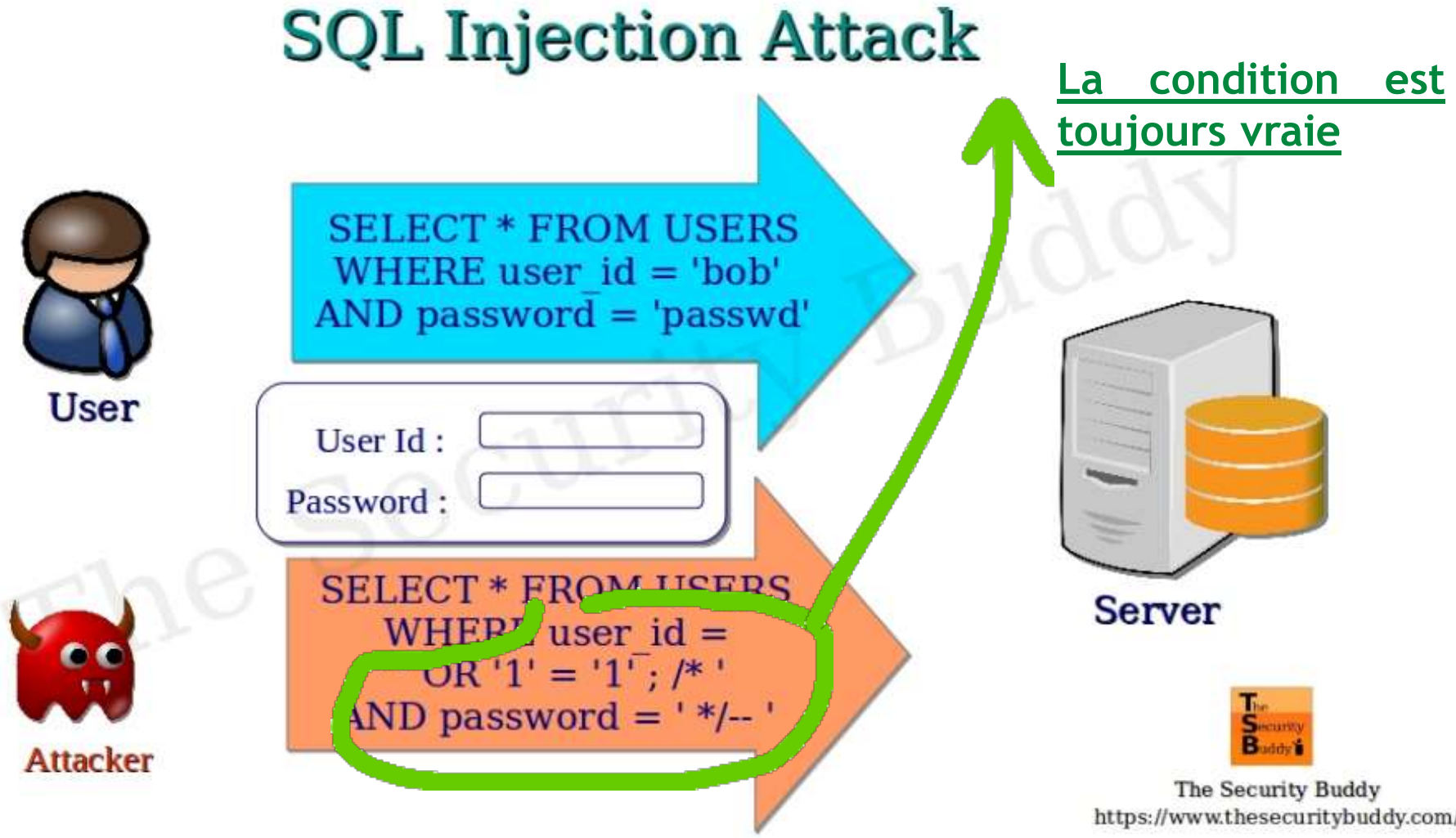


Injection SQL (1)

- **Injection SQL** (ou attaques par injection de commandes SQL)
  - exploitent les failles de sécurité d'une application qui interagit avec des bases de données.
  - elle consiste à insérer du code SQL malveillant dans les champs de saisie d'une application ou dans les paramètres de requête qui interagissent avec une base de données
  - le hacker peut ainsi accéder à la base de données, mais aussi modifier le contenu et donc compromettre la sécurité du système
  - Cette vulnérabilité exploite un traitement insuffisant ou absent de la validation des entrées utilisateurs, permettant à l'attaquant de manipuler les requêtes SQL exécutées par l'application.

Injection SQL (2)

- Exemple



Injection SQL (3)

- **Dégâts possibles**
  - Accès non autorisé aux données sensibles (identifiants, informations personnelles, financières),
  - Modification, suppression, ou ajout de données dans la base,
  - Exécution de commandes d'administration sur la base (suppression de tables, modification des tables, ..),
  - Compromission totale du système si le serveur de base de données est mal sécurisé.

Cross-Site Scripting (XSS) (1)

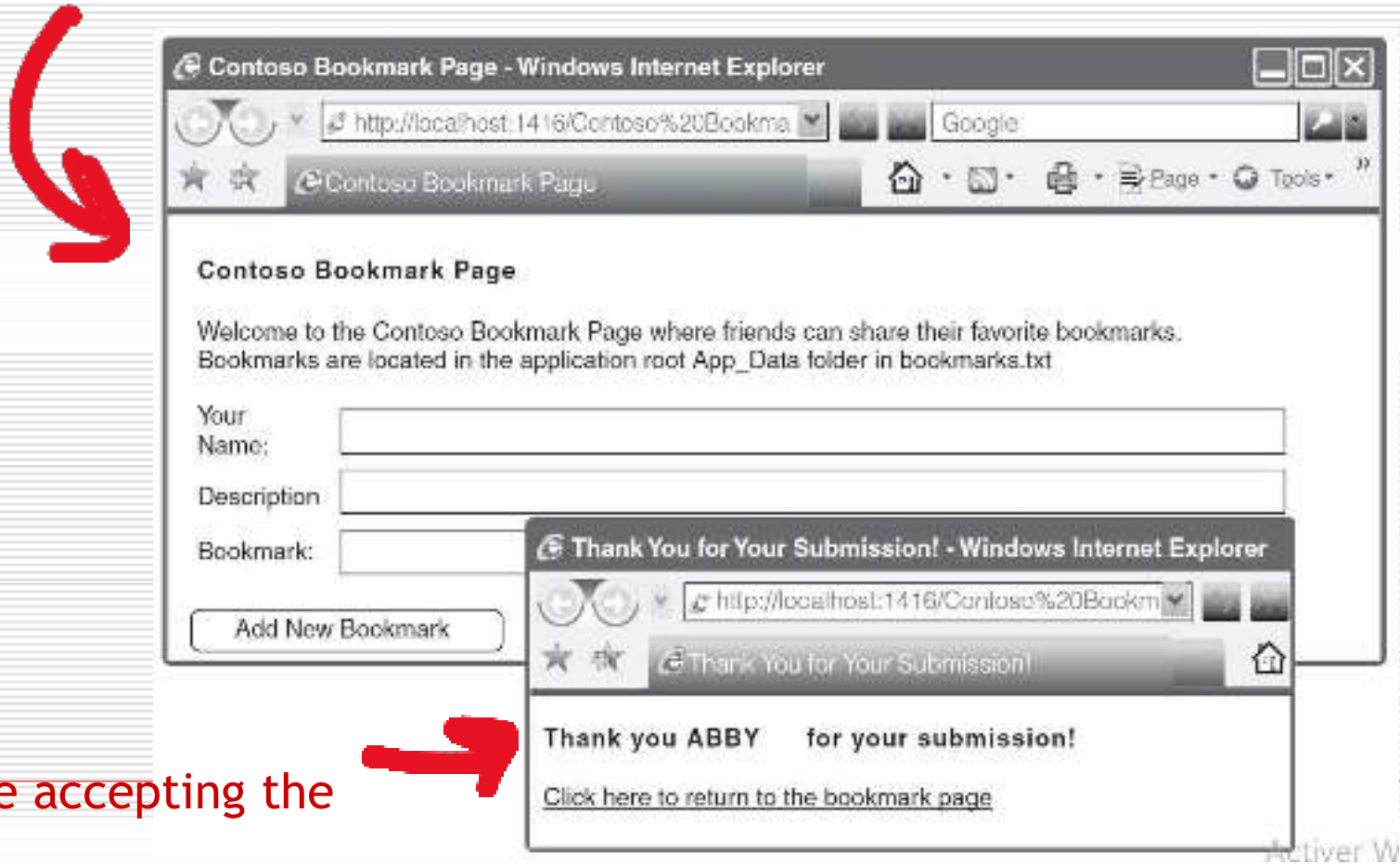
- Une attaque XSS consiste à injecter des scripts malveillants dans un site web légitime pour qu'ils soient exécutés par le navigateur de la victime
- Les conséquences peuvent inclure le vol de données sensibles (cookies, jetons de session), le détournement de sessions utilisateurs, l'installation de malwares ou la défiguration de sites web,..
- Les attaques XSS exploitent des vulnérabilités de validation des entrées utilisateur, et il existe trois principaux types : XSS réfléchi, XSS stocké et XSS basé sur DOM

Cross-Site Scripting (XSS) (2)



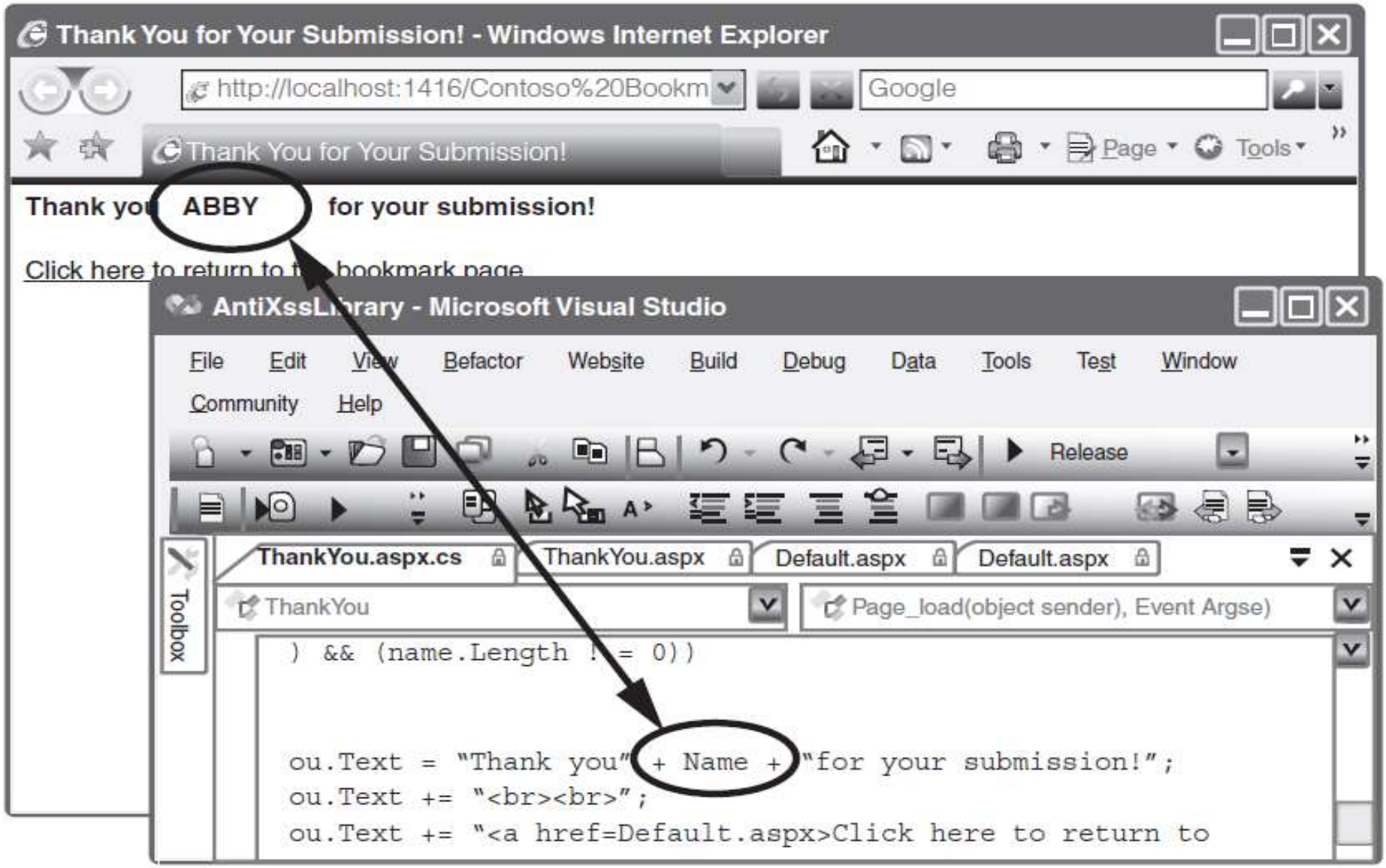
Cross-Site Scripting (XSS) (3)

- Une attaque XSS réquiert que le site web satisfait deux critères: **(1)** il accepte la saisie de données par un utilisateur et **(2)** il utilise ces données dans une réponse
- Exemple de site web acceptant user data input



Bookmark page accepting the user input

Cross-Site Scripting (XSS) (4)



user input used in response

Attaque par Détournement de session/ Session hijacking attack (1)

- Le détournement de session consiste **à détourner** un accès à une plateforme, sans avoir besoin de collecter l'identifiant et le mot de passe associé au compte ➔ **principe de Session ID**
- **Principe de session ID**
  - Lorsqu'un utilisateur se connecte à une plateforme, il reste authentifié pendant **un certain temps** sans qu'il soit nécessaire de saisir ou de retransmettre systématiquement ses identifiants de connexion. Cela est possible, car le serveur maintient une **session active** pour l'utilisateur
  - Pour faire référence à cette session, le serveur décerne à l'utilisateur un identifiant unique appelé **session ID**, le plus souvent un cookie de session
  - Lorsque l'utilisateur va réaliser des actions sur la plateforme, ce session ID, stocké dans son navigateur, va **systématiquement** être transmis au serveur afin qu'il puisse **identifier la session correspondante** ➔ Session ID est crucial car il authentifie l'utilisateur sans que ce dernier ait besoin de fournir ses identifiants

Attaque par Détournement de session/ Session hijacking attack (2)

Le détournement de session consiste donc à dérober ce session ID, de manière à prendre possession de la session active.

